

QueryGuard

A safety gate for LLM-generated SQL

M. Mahd Amjad · Arwa Arafeh

QUESTION

LLM DRAFTS SQL

GATE: 10 RULES

DATABASE

“

Every generated query
should be checked before it
touches the database.

Three CVEs since 2024 show what happens when they are not. We make the check visible and measured.

WHAT THE GATE SEES

"Show me every user account."

LLM drafts: `SELECT * FROM users; DROP
TABLE users;`

BLOCKED - multi-statement escape

Verdict logged with the rule that fired.

LLM-to-database is unsafe by default

Frameworks pass LLM-generated SQL straight to the database. Three CVEs since 2024 show the result.

1

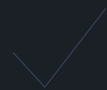
3 CVEs



Disclosed 2024-2026 in
LLM-DB frameworks

2

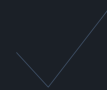
CVSS 9.8



PII extraction via
AnythingLLM

3

50% ASR



Attack success rate
without defenses

4

0 explanations



Tools never explain a
block

The problem is documented in public CVEs and academic studies; the project builds the missing layer between LLM and database.

What exists today

Retrain

StruQ, SecAlign: model-side



Requires swapping or tuning the model

Generic

NeMo, Guardrails AI



Opaque, not SQL-aware

Tools

HeimdaLLM, sql-data-guard



Gates exist, numbers don't

The gap: a check that is transparent (you can read every rule), SQL-specific (knows your schema), and measured (publishes its own mistake rate).

A transparent gate at the application layer

Four components; each becomes a numbered SRS requirement and a team lane.

Validation gate - AST rule engine (40%)

Evaluation harness - corpus + CI (20%)

Web application - UI and API (20%)

Docs, decisions and presentation (20%)

1 · Intake — session and question log



2 · Generator — LLM drafts SQL + intent



3 · VALIDATION GATE — 10 rules



4 · Executor — read-only, gate-passed only



5 · Audit log — every verdict recorded

Executor accepts only gate-passed queries

Measured, not asserted

Six attack classes from the published taxonomy; starter ships two prompts per class, target five.

Corpus — 30 attacks + 30 benign



Gate under test — all 10 rules



Gate verdicts — per rule, per class



Report — block rate + false positives

CI: any regression fails the build

100%

block rate on destructive classes

< 10% false positives, reported openly

< 50 ms

p95 gate latency per query

0

silent regressions - CI-enforced

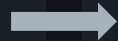
Three checkpoints, all verifiable

Every checkpoint has a receipt: submission proof, green CI, or a live demo.



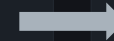
Proposal and SRS

Submitted with review comments recorded before midterm; deck follows the course style rules.



Build and CI gate

Working path from question to verdict after midterm; corpus regression green on every push.



Demo

Scripted demo with live metrics; block shown, numbers on screen, rehearsed twice.

From proposal to working gate

What the team starts this week, and what you will see by midterm.

Confirm topic, stack and lane owners

Whole team

This week

SRS requirements drafted; repo and CI skeleton live

Gate and evaluation lanes

Next two weeks

Corpus starter in CI: two prompts per attack class

All lanes

Before midterm